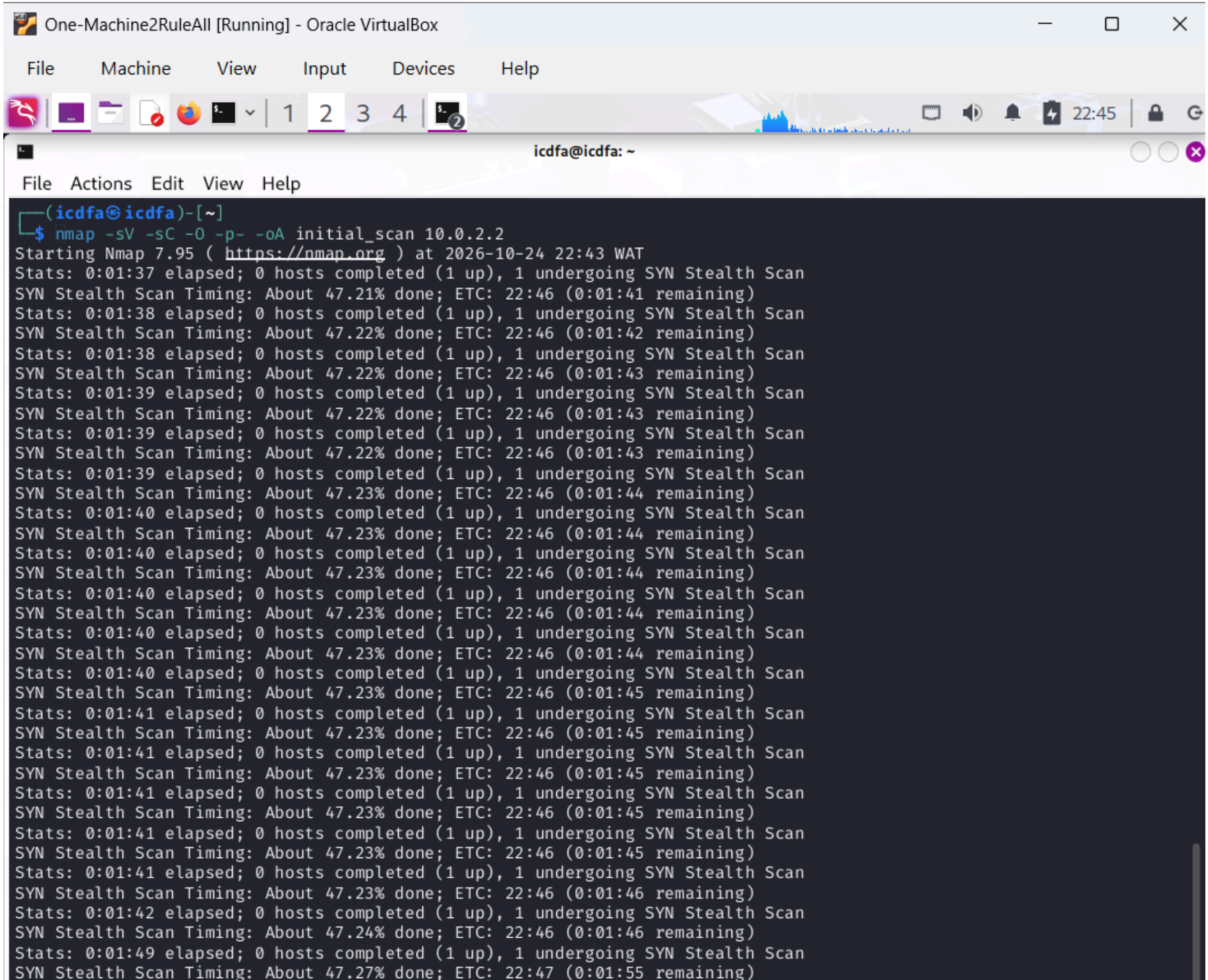
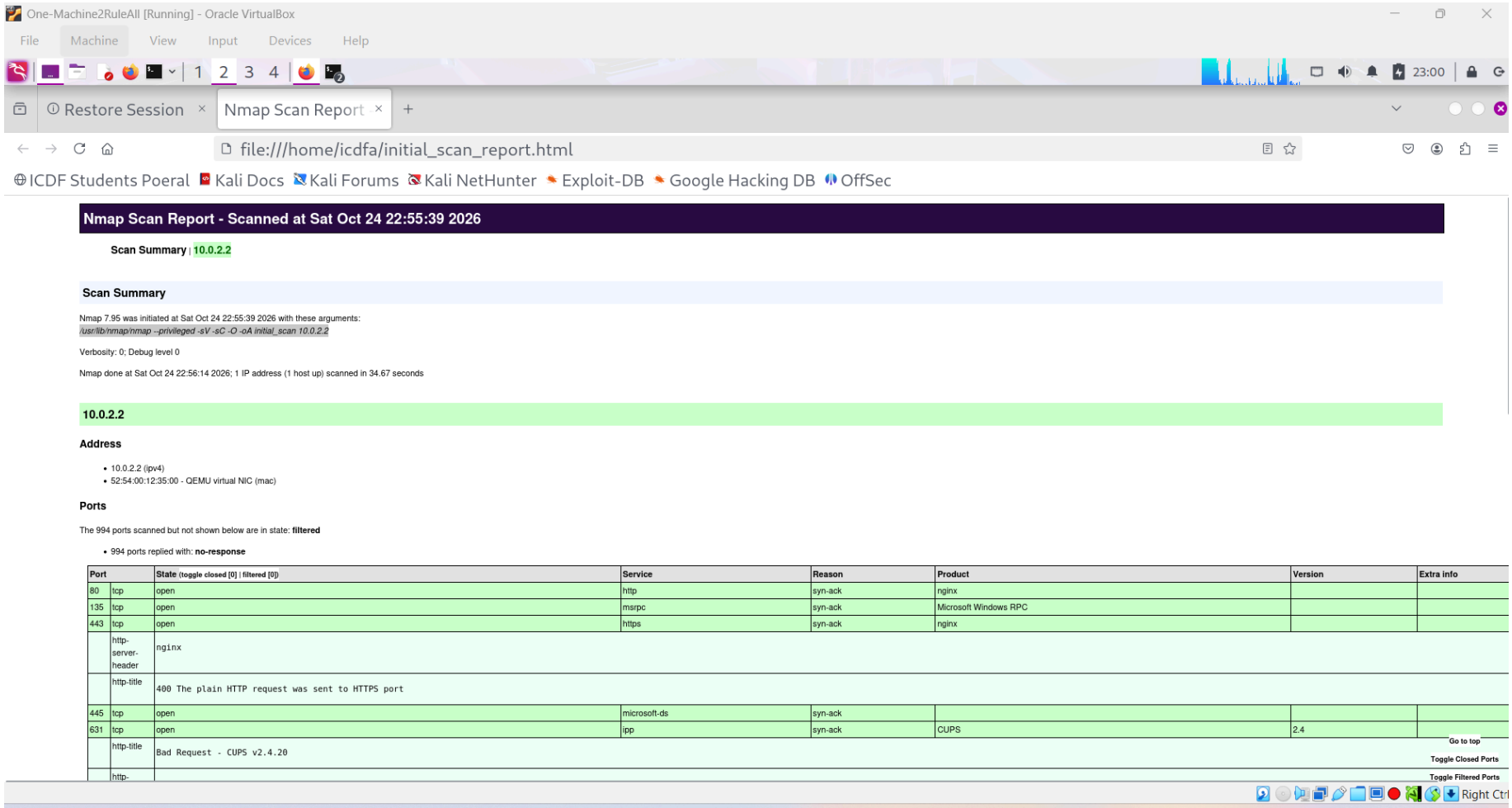
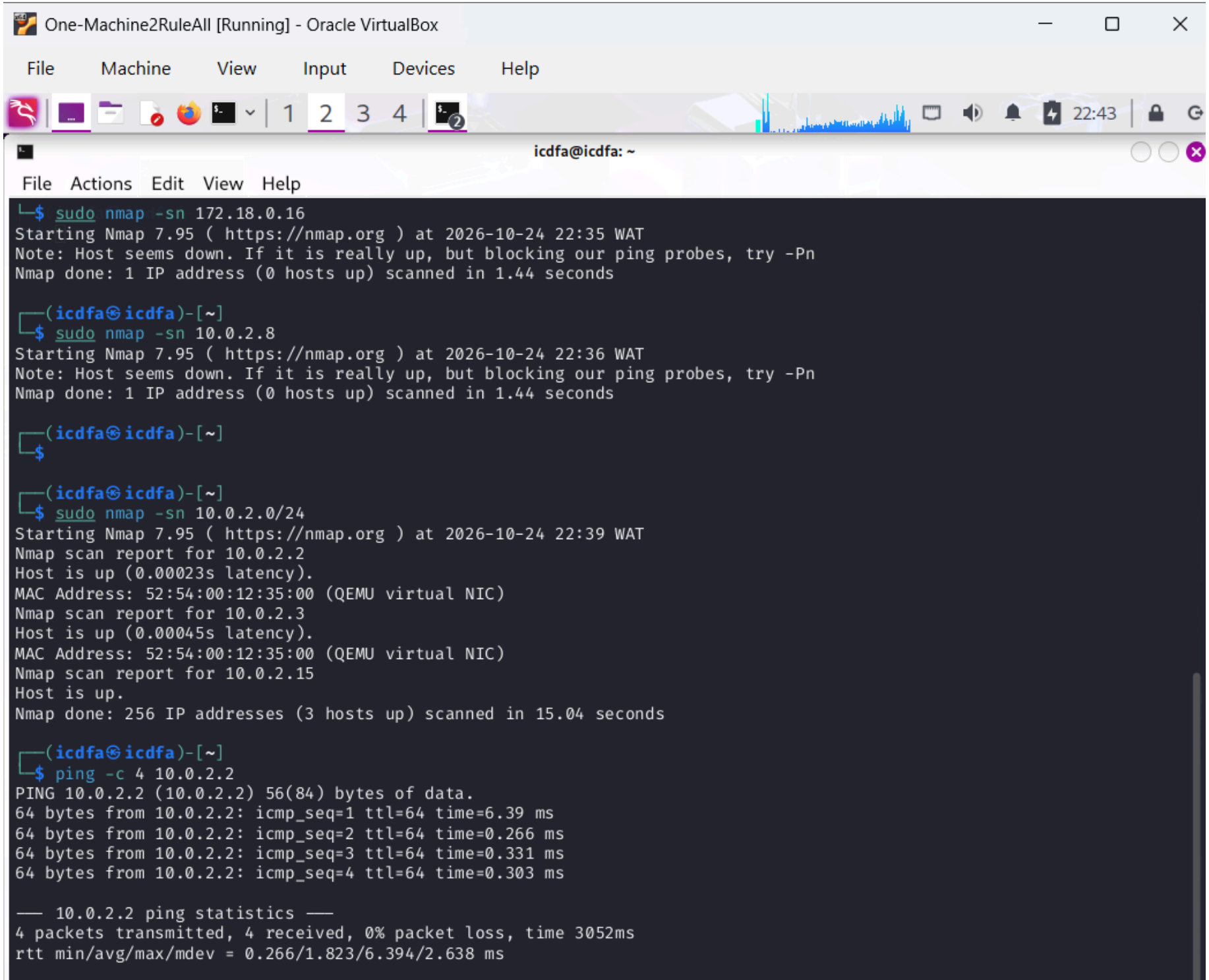
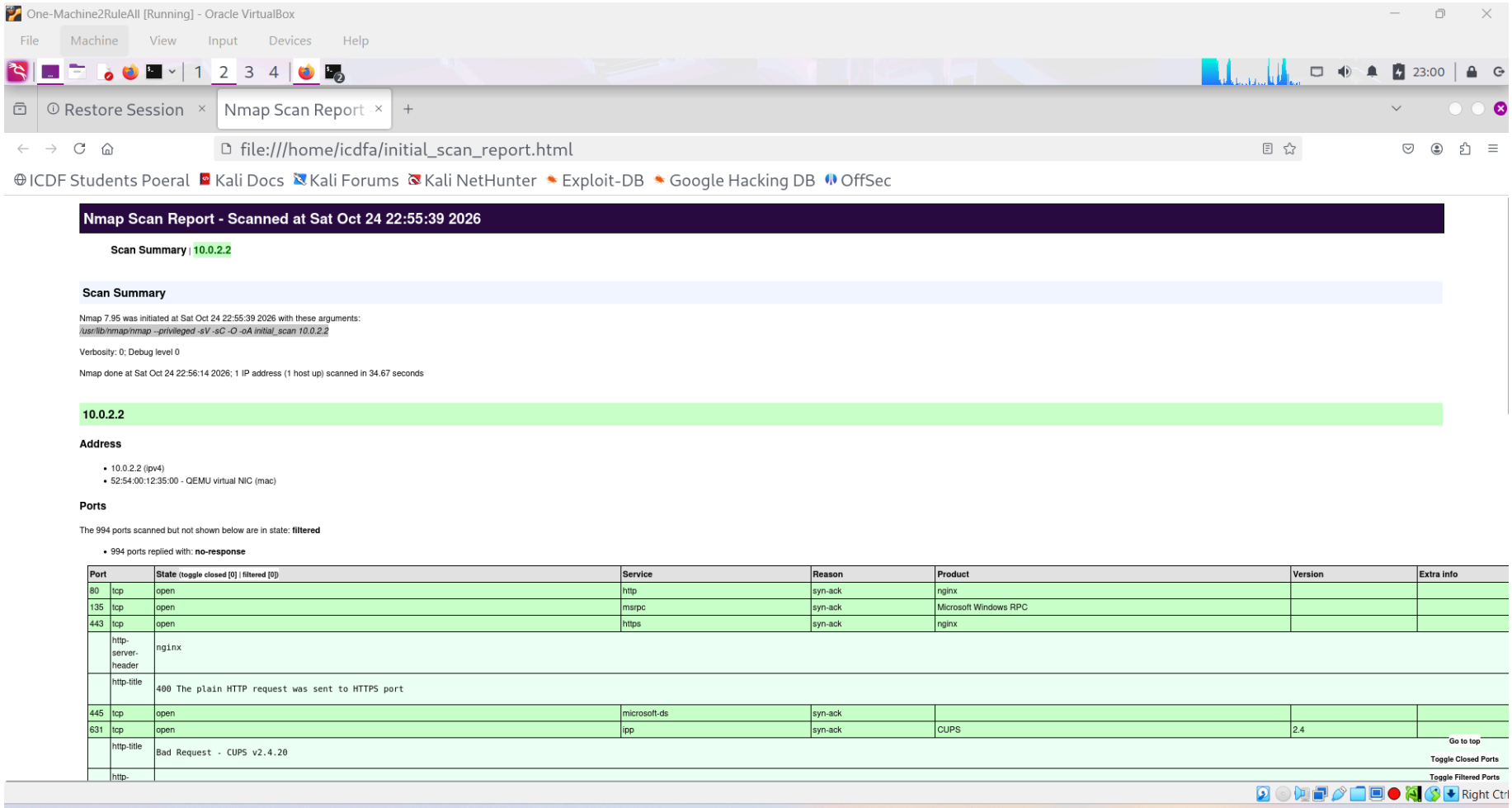
Lab 1: Practical Vulnerability Assessment for GRC Professionals

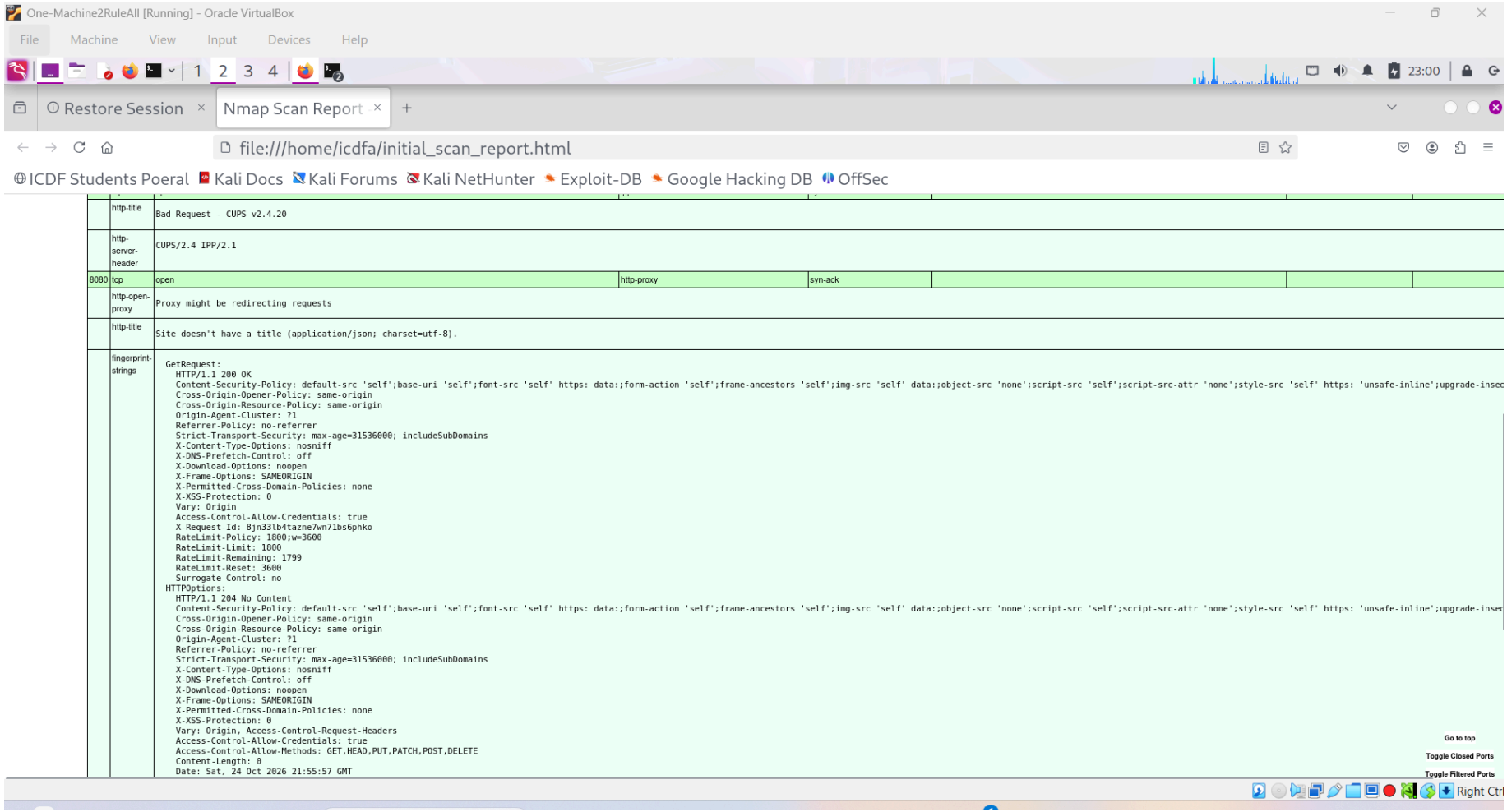
Field	Detail
Name	Adebukola Olanipekun
Registration Details	C11/26/CGRCE/17603 ,Cohort 11 CGRCE
Date	25th October, 2026

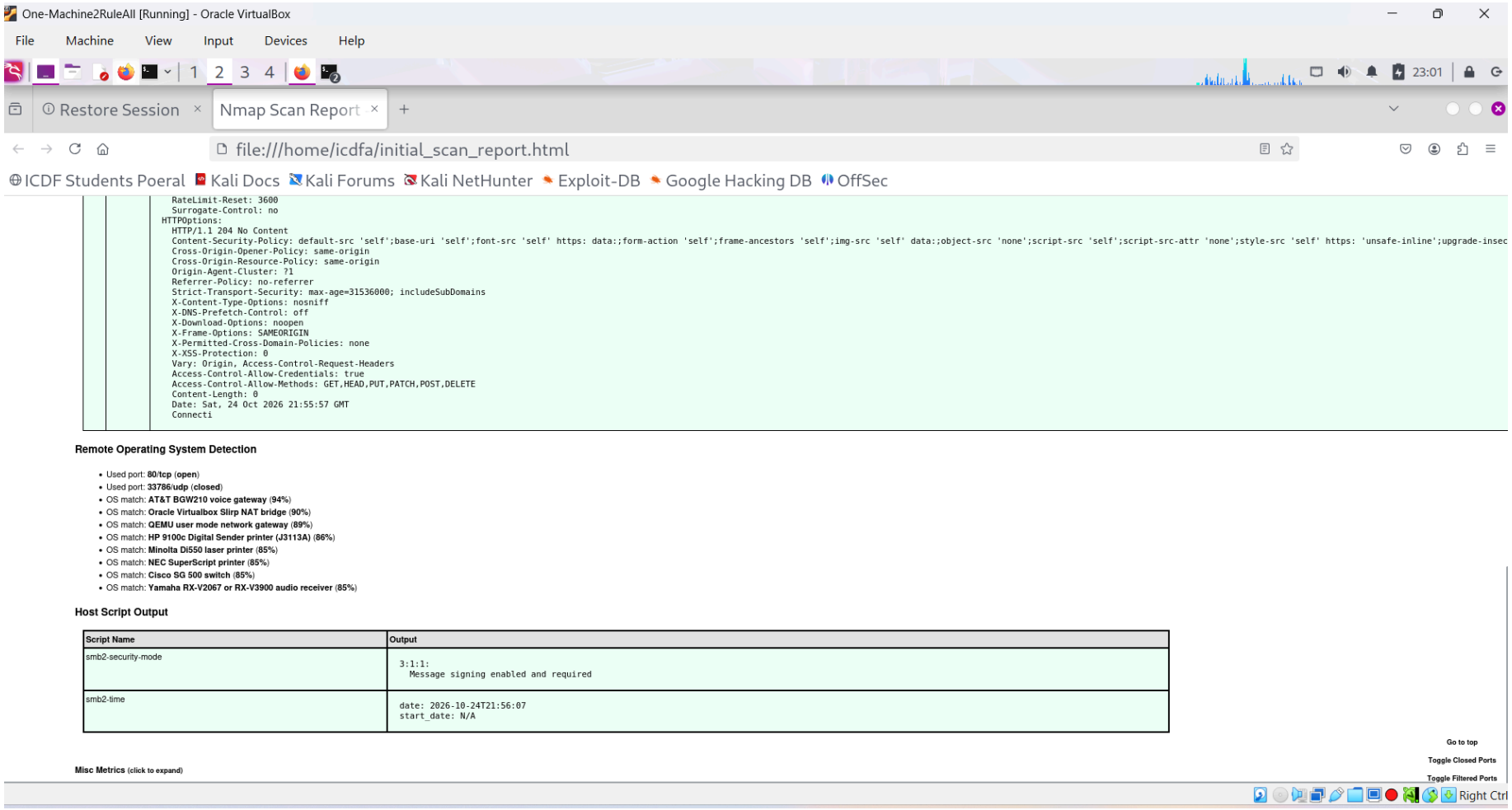

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
22:45
icdfa@icdfa: ~
File Actions Edit View Help
┌──(icdfa㉿icdfa)-[~]
└─$ nmap -sV -sC -O -p- -oA initial_scan 10.0.2.2
Starting Nmap 7.95 (https://nmap.org) at 2026-10-24 22:43 WAT
Stats: 0:01:37 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.21% done; ETC: 22:46 (0:01:41 remaining)
Stats: 0:01:38 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.22% done; ETC: 22:46 (0:01:42 remaining)
Stats: 0:01:38 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.22% done; ETC: 22:46 (0:01:43 remaining)
Stats: 0:01:39 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.22% done; ETC: 22:46 (0:01:43 remaining)
Stats: 0:01:39 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.22% done; ETC: 22:46 (0:01:43 remaining)
Stats: 0:01:39 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:44 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:44 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:44 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:44 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:44 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:45 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:45 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:45 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:45 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:45 remaining)
Stats: 0:01:41 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.23% done; ETC: 22:46 (0:01:46 remaining)
Stats: 0:01:42 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.24% done; ETC: 22:46 (0:01:46 remaining)
Stats: 0:01:49 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.27% done; ETC: 22:47 (0:01:55 remaining)

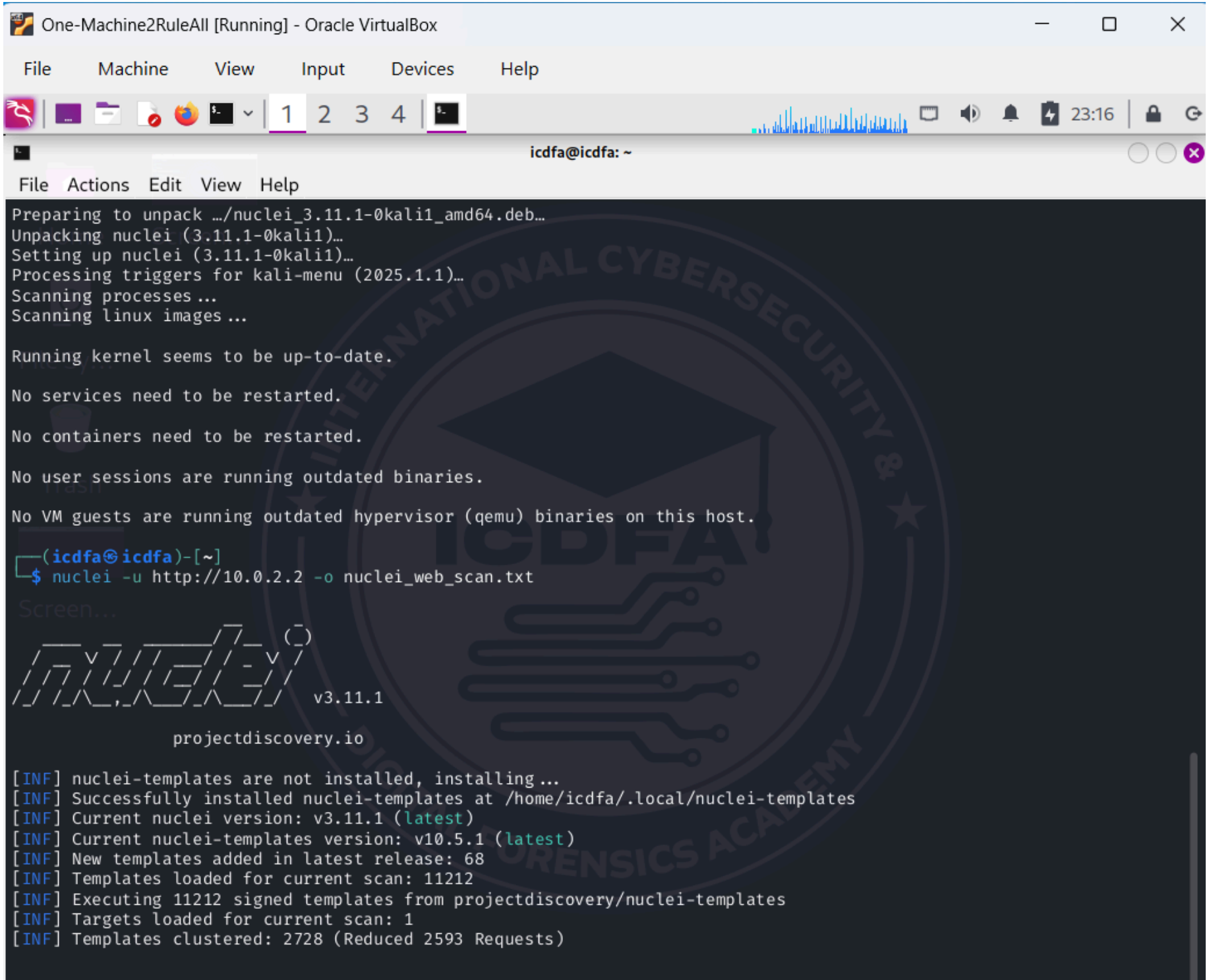

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Restore Session
Nmap Scan Report
file:///home/icdfa/initial_scan_report.html
ICDF Students Poeral
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Nmap Scan Report - Scanned at Sat Oct 24 22:55:39 2026
Scan Summary | 10.0.2.2
Scan Summary
Nmap 7.95 was initiated at Sat Oct 24 22:55:39 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -sV -sC -O -oA initial_scan 10.0.2.2
Verbosity: 0; Debug level 0
Nmap done at Sat Oct 24 22:56:14 2026; 1 IP address (1 host up) scanned in 34.67 seconds
10.0.2.2
Address
10.0.2.2 (ipv4)
52:54:00:12:35:00 - QEMU virtual NIC (mac)
Ports
The 994 ports scanned but not shown below are in state: filtered
994 ports replied with: no-response
Port
State (toggle closed [0] | filtered [0])
Service
Reason
Product
Version
Extra info
80 tcp open http syn-ack nginx
135 tcp open msrpc syn-ack Microsoft Windows RPC
443 tcp open https syn-ack nginx
http-server-header nginx
http-title 400 The plain HTTP request was sent to HTTPS port
445 tcp open microsoft-ds syn-ack
631 tcp open ipp syn-ack CUPS 2.4
http-title Bad Request - CUPS v2.4.20
Go to top
Toggle Closed Ports
Toggle Filtered Ports
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
22:43
icdfa@icdfa: ~
File Actions Edit View Help
└─$ sudo nmap -sn 172.18.0.16
Starting Nmap 7.95 (https://nmap.org) at 2026-10-24 22:35 WAT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.44 seconds
┌──(icdfa㉿icdfa)-[~]
└─$ sudo nmap -sn 10.0.2.8
Starting Nmap 7.95 (https://nmap.org) at 2026-10-24 22:36 WAT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.44 seconds
┌──(icdfa㉿icdfa)-[~]
└─$
┌──(icdfa㉿icdfa)-[~]
└─$ sudo nmap -sn 10.0.2.0/24
Starting Nmap 7.95 (https://nmap.org) at 2026-10-24 22:39 WAT
Nmap scan report for 10.0.2.2
Host is up (0.00023s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.3
Host is up (0.00045s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.15
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 15.04 seconds
┌──(icdfa㉿icdfa)-[~]
└─$ ping -c 4 10.0.2.2
PING 10.0.2.2 (10.0.2.2) 56(84) bytes of data.
64 bytes from 10.0.2.2: icmp_seq=1 ttl=64 time=6.39 ms
64 bytes from 10.0.2.2: icmp_seq=2 ttl=64 time=0.266 ms
64 bytes from 10.0.2.2: icmp_seq=3 ttl=64 time=0.331 ms
64 bytes from 10.0.2.2: icmp_seq=4 ttl=64 time=0.303 ms
— 10.0.2.2 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3052ms
rtt min/avg/max/mdev = 0.266/1.823/6.394/2.638 ms


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Restore Session
Nmap Scan Report
file:///home/icdfa/initial_scan_report.html
ICDF Students Poeral
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
Nmap Scan Report - Scanned at Sat Oct 24 22:55:39 2026
Scan Summary | 10.0.2.2
Scan Summary
Nmap 7.95 was initiated at Sat Oct 24 22:55:39 2026 with these arguments:
/usr/lib/nmap/nmap --privileged -sV -sC -O -oA initial_scan 10.0.2.2
Verbosity: 0; Debug level 0
Nmap done at Sat Oct 24 22:56:14 2026; 1 IP address (1 host up) scanned in 34.67 seconds
10.0.2.2
Address
10.0.2.2 (ipv4)
52:54:00:12:35:00 - QEMU virtual NIC (mac)
Ports
The 994 ports scanned but not shown below are in state: filtered
994 ports replied with: no-response
Port
State (toggle closed [0] | filtered [0])
Service
Reason
Product
Version
Extra info
80 tcp open http syn-ack nginx
135 tcp open msrpc syn-ack Microsoft Windows RPC
443 tcp open https syn-ack nginx
http-server-header nginx
http-title 400 The plain HTTP request was sent to HTTPS port
445 tcp open microsoft-ds syn-ack
631 tcp open ipp syn-ack CUPS 2.4
http-title Bad Request - CUPS v2.4.20
Go to top
Toggle Closed Ports
Toggle Filtered Ports
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Restore Session
Nmap Scan Report
file:///home/icdfa/initial_scan_report.html
ICDF Students Poeral
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
http-title
Bad Request - CUPS v2.4.20
http-server-header
CUPS/2.4 IPP/2.1
8080 tcp open http-proxy syn-ack
http-open-proxy
Proxy might be redirecting requests
http-title
Site doesn't have a title (application/json; charset=utf-8).
fingerprint-strings
GetRequest:
HTTP/1.1 200 OK
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insec
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-DNS-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-XSS-Protection: 0
Vary: Origin
Access-Control-Allow-Credentials: true
X-Request-Id: 8jn33lb4tazne7wn71bs6phko
RateLimit-Policy: 1800;w=3600
RateLimit-Limit: 1800
RateLimit-Remaining: 1799
RateLimit-Reset: 3600
Surrogate-Control: no
HTTPOptions:
HTTP/1.1 204 No Content
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insec
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-DNS-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-XSS-Protection: 0
Vary: Origin, Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Methods: GET,HEAD,PUT,PATCH,POST,DELETE
Content-Length: 0
Date: Sat, 24 Oct 2026 21:55:57 GMT
Go to top
Toggle Closed Ports
Toggle Filtered Ports
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Restore Session
Nmap Scan Report
file:///home/icdfa/initial_scan_report.html
ICDF Students Poeral
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
RateLimit-Reset: 3600
Surrogate-Control: no
HTTPOptions:
HTTP/1.1 204 No Content
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insec
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-DNS-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-XSS-Protection: 0
Vary: Origin, Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Methods: GET,HEAD,PUT,PATCH,POST,DELETE
Content-Length: 0
Date: Sat, 24 Oct 2026 21:55:57 GMT
Connecti
Remote Operating System Detection
Used port: 80/tcp (open)
Used port: 33786/udp (closed)
OS match: AT&T BGW210 voice gateway (94%)
OS match: Oracle Virtualbox Slirp NAT bridge (90%)
OS match: QEMU user mode network gateway (89%)
OS match: HP 9100c Digital Sender printer (J3113A) (86%)
OS match: Minolta Di550 laser printer (85%)
OS match: NEC SuperScript printer (85%)
OS match: Cisco SG 500 switch (85%)
OS match: Yamaha RX-V2067 or RX-V3900 audio receiver (85%)
Host Script Output
Script Name
Output
smb2-security-mode
3:1:1:
Message signing enabled and required
smb2-time
date: 2026-10-24T21:56:07
start_date: N/A
Go to top
Toggle Closed Ports
Toggle Filtered Ports
Misc Metrics (click to expand)
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
23:16
icdfa@icdfa: ~
File Actions Edit View Help
Preparing to unpack …/nuclei_3.11.1-0kali1_amd64.deb…
Unpacking nuclei (3.11.1-0kali1)…
Setting up nuclei (3.11.1-0kali1)…
Processing triggers for kali-menu (2025.1.1)…
Scanning processes ...
Scanning linux images ...
Running kernel seems to be up-to-date.
No services need to be restarted.
No containers need to be restarted.
No user sessions are running outdated binaries.
No VM guests are running outdated hypervisor (qemu) binaries on this host.
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -u http://10.0.2.2 -o nuclei_web_scan.txt
v3.11.1
projectdiscovery.io
[INF] nuclei-templates are not installed, installing ...
[INF] Successfully installed nuclei-templates at /home/icdfa/.local/nuclei-templates
[INF] Current nuclei version: v3.11.1 (latest)
[INF] Current nuclei-templates version: v10.5.1 (latest)
[INF] New templates added in latest release: 68
[INF] Templates loaded for current scan: 11212
[INF] Executing 11212 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2728 (Reduced 2593 Requests)

Risk Assessment Table

Target: Internal development server “metasploitable” **Prepared by:** GRC Audit Team **Date:** October 24, 2026

Finding	Affected Service	CVE / Reference	Inherent Risk (L/M/H)	Compliance Violation	Business Impact
vsFTPd 2.3.4 Backdoor	FTP (Port 21/tcp), vsftpd 2.3.4	CVE-2011-2523	**High (H)**	CIS Controls v8, 7.4: Perform Automated Application Patch Management (a known-vulnerable version is running unpatched).	Full system compromise. A remote attacker can trigger the backdoor and obtain an unauthenticated root shell, allowing data theft, tampering, and a foothold for attacks on other systems.
Unencrypted Telnet Service	Telnet (Port 23/tcp)	N/A (no CVE). CWE-319: Cleartext Transmission of Sensitive Information	**High (H)**	NIST CSF 1.1, PR.DS-2: Data-in-transit is protected. CIS Controls v8, 4.8: Uninstall or Disable Unnecessary Services.	Credential theft. Passwords and commands travel in plain text, so anyone who can sniff the network can capture administrator logins and take over the server.
Weak / Default Credentials	SSH (22/tcp), FTP (21/tcp), Telnet (23/tcp)	N/A (no CVE). CWE-521: Weak Password Requirements; CWE-1392: Use of Default Credentials	**High (H)**	CIS Controls v8, 4.7: Manage Default Accounts on Enterprise Assets and Software; 5.2: Use Unique Passwords.	Unauthorized access. Attackers can guess or look up default passwords and log in without exploiting any software flaw.

EXECUTIVE MEMO

To: IT Management
From: GRC Audit Team
Date: October 24, 2026
Subject: High-Risk Findings on Development Server 'metasploitable'

1. Executive Summary:
A vulnerability assessment of the internal development server ("metasploitable") revealed multiple critical security vulnerabilities that pose an immediate and high risk to the organization's information assets. The system is non-compliant with several key organizational policies, specifically regarding patch management and secure configuration standards. Immediate remediation is required to prevent a data breach.

2. Key Findings & Risks:

- Critical Risk - Remote System Compromise: The FTP service (Port 21) is running vsFTPd version 2.3.4, which contains a known backdoor (CVE-2011-2523). This allows an attacker to gain full, unauthenticated root control of the server. This is a direct violation of our patch management policy (CIS Control 7.1).
- High Risk - Data Interception: The server is running Telnet (Port 23), which transmits all data, including administrative credentials, in plaintext. This violates data protection standards (NIST CSF PR.DS-2) and exposes the organization to credential theft and espionage.
- High Risk - Weak Authentication: The system is configured with default and weak passwords across multiple services (SSH, FTP). This significantly increases the risk of unauthorized access, violating CIS Control 5.2.

3. Recommended Actions:

1. Immediate Isolation: Remove the 'metasploitable' server from the internal network until remediation is complete to prevent exploitation.
2. Remediate: Apply security patches to update or remove the vulnerable vsFTPd service.
3. Harden: Disable unnecessary services (specifically Telnet and Rlogin) and enforce a strong password policy across all administrative accounts.
4. Process Review: Reinforce standard procedures for deploying systems to ensure they adhere to the organization's security baseline before connecting to the network.

Memorandum

To: IT Management

From: GRC Audit Team

Date: October 24, 2026

Subject: High-Risk Findings on Development Server 'metasploitable'

---

1. Executive Summary

A vulnerability assessment of the internal development server ("metasploitable") found multiple high-risk security vulnerabilities that pose an immediate threat to the organization's information assets. The system does not comply with several organizational policies, specifically those covering patch management and secure configuration. Immediate remediation is required to prevent a data breach.

2. Key Findings and Risks

- **High Risk - Remote System Compromise:** The FTP service (Port 21) runs vsFTPd version 2.3.4, which contains a known backdoor (CVE-2011-2523). This allows an attacker to gain unauthenticated, root-level control of the server. It is a direct violation of our patch management policy (CIS Control 7.4).
- **High Risk - Data Interception:** The server runs Telnet (Port 23), which transmits all data, including administrative credentials, in plain text. This violates data protection standards (NIST CSF PR.DS-2) and exposes the organization to credential theft and espionage.
- **High Risk - Weak Authentication:** The system uses default and weak passwords across multiple services (SSH, FTP, Telnet). This greatly increases the risk of unauthorized access and violates CIS Controls 4.7 and 5.2.

3. Recommended Actions

1. **Immediate isolation:** Remove the 'metasploitable' server from the internal network until remediation is complete, to prevent exploitation.
2. **Remediate:** Update or remove the vulnerable vsFTPd service and apply all available security patches.
3. **Harden:** Disable unnecessary services (specifically Telnet, and any other legacy remote-access services found in the scan) and enforce a strong password policy on all administrative accounts.
4. **Process review:** Reinforce standard deployment procedures so that systems meet the organization's security baseline before they are connected to the network.